

1 Umzug und Betrieb des Thesis Match Maker

Empfänger:innen: IT-Verantwortliche, Fachbereichsverwaltung und Projektleitung

Stand: 21. August 2026

Ziel: Der Thesis Match Maker soll auf einem eigenen Server bei IONOS oder Hetzner laufen und dabei unabhängig von der bisherigen Plattform betrieben werden.

Wichtig vor dem Start: Die Live-Anwendung verarbeitet personenbezogene Daten und private Prüfungsunterlagen. Arbeiten Sie deshalb nur mit einem aktuellen, verschlüsselten Export und führen Sie keine DNS-Umstellung durch, bevor die neue Installation vollständig getestet wurde.

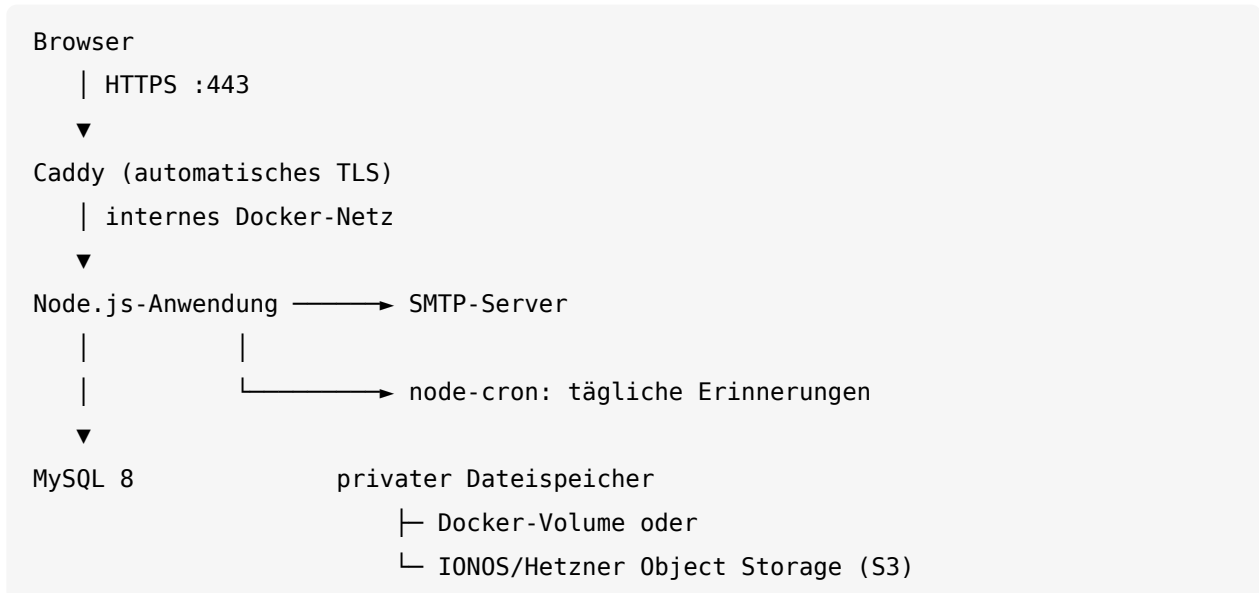
1.1 1. Was wird umgezogen?

Der Umzug umfasst nicht nur den Quellcode. Für einen funktionsfähigen Betrieb werden auch die MySQL-Datenbank, gespeicherte Dateien, die E-Mail-Konfiguration, Sicherheitsgeheimnisse, die Domain und die Hintergrundaufgaben benötigt. Das Übergabepaket trennt bewusst die **Software** von den **Produktivdaten**. Der Quellcode kann gefahrlos weitergegeben werden; Datenbankdumps, Dokumente und Geheimnisse dürfen nur verschlüsselt und mit beschränktem Zugriff gespeichert werden.

Bestandteil	Inhalt	Umgang beim Umzug
Anwendung	React-Oberfläche, Node.js-Server, Rollenlogik, PDF- und Exportfunktionen	ist Bestandteil des Quellarchivs
Datenbank	Nutzer:innen, Rollen, Thesis-Fälle, Protokolle, Fristen, Einstellungen und E-Mail-Vorlagen	aus einem konsistenten SQL-Dump wiederherstellen
Dateispeicher	Exposés, vertrauliche Anlagen, Profilbilder, Logos, Leitfäden und weitere Uploads	in privaten S3-Bucket oder verschlüsseltes Server-Volume übertragen
E-Mail	SMTP-Zugang für Freigaben, Passwort-Resets, Erinnerungen und Statusmeldungen	neue Zugangsdaten sicher in <code>deploy/.env</code> hinterlegen
Sicherheit	Sitzungsschlüssel, Cron-Schlüssel, 2FA-Verschlüsselungsschlüssel	niemals in das Quellarchiv schreiben
Domain	thesis.htw-berlin.com	erst nach erfolgreichen Tests auf den neuen Server umstellen

1.2 2. Welche Zielarchitektur wird empfohlen?

Für den ersten unabhängigen Betrieb genügt ein einzelner Linux-Server mit Docker. Die Datenbank ist innerhalb eines nicht öffentlich erreichbaren Docker-Netzes gekapselt. Caddy nimmt die HTTPS-Anfragen aus dem Internet entgegen und leitet sie intern an die Anwendung weiter. Die Anwendung selbst versendet E-Mails per SMTP, verarbeitet die täglichen Erinnerungen über einen lokalen Scheduler und speichert Dateien entweder in einem Docker-Volume oder in einem privaten, S3-kompatiblen Bucket.



Die bereitgestellte Compose-Datei startet diese drei Dienste. Der Datenbankport **wird nicht** ins öffentliche Internet veröffentlicht. Die Konfiguration `deploy/Caddyfile` fordert und erneuert HTTPS-Zertifikate automatisch, sobald die Domain auf den Server zeigt.

1.3 3. IONOS oder Hetzner?

Beide Anbieter eignen sich. Die Wahl sollte nicht nur anhand eines Lockangebots erfolgen, sondern anhand der verfügbaren Administration, des Supports und der eigenen Betriebsroutine. IONOS bewirbt VPS-Angebote mit Root-Zugriff, Firewall-Verwaltung, Backup-Optionen und deutschsprachigem 24/7-Support. Das auf der Produktseite genannte VPS L+ umfasst 6 vCores, 8 GB RAM und 240 GB NVMe; der dargestellte reguläre Preis beträgt 18 EUR pro Monat, während Aktionspreise und Vertragsbedingungen zeitlich begrenzt sein können. [1]

Hetzner bietet Cloud-Server in deutschen Rechenzentren sowie Firewall-Funktionen und Ubuntu-Images. Für eine normale Webanwendung mit Datenbank sollte eine Instanz mit mindestens 4 vCPU, 8 GB RAM und 80–160 GB SSD gewählt werden. Der genaue Tarifpreis hängt von Tarifklasse, Standort und Steuereinstellung ab und muss im aktuellen Preisrechner vor Bestellung geprüft werden. [2]

Kriterium	IONOS VPS	Hetzner Cloud	Empfehlung für dieses Projekt
Einstieg ohne viel Administration	persönlicher Support und vorkonfigurierte VPS-Angebote	gute Dokumentation, mehr Selbstverwaltung	IONOS, wenn Support wichtiger ist

Kriterium	IONOS VPS	Hetzner Cloud	Empfehlung für dieses Projekt
Kosten-/Leistungsorientierter Linux-Betrieb	gute VPS-Auswahl	sehr flexible Cloud-Instanzen	Hetzner, wenn eine technisch betreute Administration vorhanden ist
Objekt-Speicher	S3-kompatibel, nutzungsabhängig, Object Lock verfügbar [3]	S3-kompatibel, Object Lock und vorab signierte URLs verfügbar [4]	beide geeignet; privater Bucket verpflichtend
Erstbetrieb	ein Server ausreichend	ein Server ausreichend	keine Hochverfügbarkeitsplattform vorzeitig beschaffen

Technische Empfehlung: Für eine engagierte IT-Administration ist Hetzner Cloud mit einem privaten Object-Storage-Bucket eine pragmatische Lösung. Wenn ein klarer Ansprechpartner und ein stärker betreuter VPS-Vertrag wichtiger sind, ist IONOS VPS passend. In beiden Fällen sollten Server, Backups und Object Storage in der EU betrieben werden. Die Beschaffung muss die aktuellen Vertragsbedingungen, Steuerangaben und die Datenschutzvereinbarung des jeweiligen Anbieters prüfen.

1.4 4. Kostenrahmen

Die folgenden Werte sind eine **Orientierung**, keine Preiszusage. Serverpreise, Rabattzeiträume, Mehrwertsteuer, Backups, Traffic und Speicherverbrauch können sich ändern. Die aktuellen Anbieterpreise sind vor der Bestellung im jeweiligen Kundenkonto zu bestätigen.

Kostenblock	Minimaler Startbetrieb	Robuster Regelbetrieb	Hinweise
Linux-Server	ab etwa 4 vCPU, 8 GB RAM, 80–160 GB SSD	6 vCPU, 8 GB RAM, 160–240 GB SSD	IONOS listet für VPS L+ 18 EUR/Monat regulär; andere Tarife und Hetzner-Preise vor Bestellung prüfen. [1] [2]
Objekt-Speicher	optional bei wenigen Dateien	empfohlen für private Dateien und Offsite-Backups	IONOS nennt 0,00487 USD/GB pro 30 Tage für Object Storage; Datentransfer kann zusätzlich anfallen. [3]

Kostenblock	Minimaler Startbetrieb	Robuster Regelbetrieb	Hinweise
Backups	zweites verschlüsseltes Ziel	tägliche Sicherung + regelmäßiger Restore-Test	nicht nur Server-Snapshot verwenden
Domain	bestehende Domain weiterverwenden	bestehende Domain weiterverwenden	keine neue Domain notwendig
E-Mail	vorhandener Hochschul-SMTP	transaktionaler SMTP mit EU-Verarbeitung	Zugang und Absenderfreigabe früh klären

1.5 5. Vor dem Umzug: Sicherheits- und Verantwortungsscheck

Bevor ein Server bestellt oder DNS geändert wird, muss die Projektleitung die folgenden Verantwortlichkeiten eindeutig festlegen. Dies verhindert, dass die Anwendung nach dem Umzug technisch läuft, aber niemand Sicherheitsupdates, Backups oder Störungen betreut.

Rolle	Aufgabe	Benannte Person oder Stelle
Technische Administration	Serverzugang, Updates, Firewall, Docker, Monitoring	ausfüllen
Datenverantwortung	Freigabe von Datenexport, Aufbewahrung und Löschung	ausfüllen
DNS-Verwaltung	A-/AAAA-Record und Domainzugriff	ausfüllen
E-Mail-Verwaltung	SMTP-Zugang und Absenderadresse	ausfüllen
Fachliche Freigabe	Test der Rollen, Fristen und E-Mail-Vorlagen	ausfüllen
Notfallkontakt	Erreichbarkeit bei Ausfall	ausfüllen

Die Umstellung darf erst erfolgen, wenn jede dieser Rollen erreichbar ist und ein aktuelles Backup mit Prüfsumme vorliegt.

1.6 6. Datenexport aus der bisherigen Umgebung

Die vollständige Plattform-Sicherung ist ein **Punkt-in-Zeit-Schnappschuss**. Sie enthält Quellcode, statische Dateien, Datenbank, Konfiguration und Geheimnisse, wird aber nach der Erstellung nicht weiter synchronisiert. Neue Registrierungen, Uploads oder Statusänderungen nach dem Export fehlen daher. Für eine live genutzte Anwendung sind mehrere aktuelle Exporte und ein letzter Export unmittelbar vor dem endgültigen Umschalten erforderlich. [5]

Wenn die aktuelle Konto- oder In-App-Mitteilung einen Plattform-Backupbedarf anzeigt, ist vor dem offiziellen Stichtag ein **Task Data Backup** über die dafür vorgesehene Exportoberfläche zu erstellen. Der vollständige Exportweg lautet dort „Export task data → Export more → All tasks → All time“. Bei einer Website mit Live-Nutzung empfiehlt die offizielle Anleitung wiederholte Sicherungen und einen finalen Export möglichst nah am Stichtag. [5]

Nicht ausreichend: Ein Git-Repository oder ein Quellcode-ZIP enthält keine Produktivdatenbank und keine hochgeladenen Dateien. Es ersetzt keinen vollständigen Datenexport. [5]

Neben dem Plattformexport wird nach der ersten unabhängigen Inbetriebnahme mit `scripts/selfhosted/backup.sh` ein eigener MySQL- und Speicherexport erzeugt. Das Skript erstellt Prüfsummen; `verify-backup.sh` prüft Lesbarkeit und Integrität. Ein Restore-Test auf einem getrennten Testserver ist trotzdem erforderlich.

1.7 7. Server vorbereiten

Die folgenden Schritte gelten für Ubuntu 24.04 LTS. Für IONOS oder Hetzner werden ein Ubuntu-Server, eine feste IPv4-Adresse und die Berechtigung zur Firewall-Konfiguration benötigt.

```
sudo apt update && sudo apt upgrade -y
sudo apt install -y ca-certificates curl git unzip zip ufw fail2ban

# Nur SSH und die Webports freigeben.
sudo ufw allow OpenSSH
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
sudo ufw enable
```

Docker und das Compose-Plugin werden nach der jeweils aktuellen offiziellen Docker-Anleitung installiert. Anschließend wird ein nicht privilegierter Betriebsnutzer eingerichtet. Verwenden Sie für SSH ausschließlich Schlüssel, deaktivieren Sie nach erfolgreichem Test die Passwortanmeldung und bewahren Sie einen zweiten administrativen Zugang sicher auf.

```
sudo adduser thesisops
sudo usermod -aG sudo,docker thesisops
```

1.8 8. Übergabepaket auf den Server übertragen

Das Quellarchiv enthält Software und Dokumentation, aber absichtlich keine Produktivdaten und keine echten Geheimnisse. Übertragen Sie es verschlüsselt, prüfen Sie die Prüfsumme und entpacken Sie es beispielsweise nach `/srv/thesis-match-maker`.

```
sudo mkdir -p /srv/thesis-match-maker
sudo chown thesisops:thesisops /srv/thesis-match-maker
cd /srv/thesis-match-maker
unzip thesis-match-maker-source-YYYYMMDDTHHMMSSZ.zip
```

```
# Konfigurationsvorlage kopieren, dann nur auf dem Server mit echten Werten füllen.
cp deploy/environment.example deploy/.env
chmod 600 deploy/.env
nano deploy/.env
```

Lesen Sie vor dem Eintragen der Werte `deploy/SECRETS.md`. Besonders wichtig ist `TWO_FACTOR_ENCRYPTION_KEY`: Wird ein bestehender 2FA-Bestand übernommen, muss derselbe Schlüssel sicher aus dem Altsystem übertragen werden. Ist das nicht möglich, muss für betroffene Konten eine kontrollierte Neueinrichtung der Zwei-Faktor-Authentifizierung geplant werden.

1.9 9. Erstinstallation und Datenimport

Starten Sie zunächst nur die Datenbank. Importieren Sie anschließend den echten SQL-Dump und die Dateien. Ein automatisch aus dem Quellcode erzeugtes Schema darf den produktiven Dump nicht ersetzen, weil im Bestandscheck abweichende historische Spaltenbezeichnungen festgestellt wurden.

```
# In /srv/thesis-match-maker
docker compose --env-file deploy/.env -f deploy/docker-compose.yml up -d db

# Datenbankdump einspielen – Pfad an Ihr gesichertes Backup anpassen.
gunzip -c /pfad/zu/database.sql.gz | \
  docker compose --env-file deploy/.env -f deploy/docker-compose.yml exec -T db \
  mysql -u"$MYSQL_USER" -p"$MYSQL_PASSWORD" "$MYSQL_DATABASE"

# Danach Stack starten.
docker compose --env-file deploy/.env -f deploy/docker-compose.yml up -d --build
```

Für den lokalen Dateispeicher wird `storage-local.tar.gz` wie folgt eingespielt. Bei S3 müssen die Objekte in den privaten Bucket übertragen werden; die Anwendung verwendet danach die vorhandenen Speicherreferenzen.

```
cat /pfad/zu/storage-local.tar.gz | \
  docker compose --env-file deploy/.env -f deploy/docker-compose.yml exec -T app \
  tar -C /app/storage-data -xzf -
```

Die mitgelieferte Datei `scripts/selfhosted/restore.sh` bündelt diese Schritte und verlangt vor der Überschreibung ausdrücklich das Wort `RESTORE`.

1.10 10. Testplan vor der DNS-Umstellung

Verwenden Sie zunächst eine Testadresse oder den lokalen Hostnamen. Prüfen Sie nicht nur die Startseite, sondern die fachlich kritischen Prozesse. Dokumentieren Sie für jeden Test Datum, prüfende Person und Ergebnis.

Test	Erwartetes Ergebnis
Containerstatus	db, app und caddy sind „healthy“ beziehungsweise laufen fehlerfrei
Startseite und FAQ	HTTPS funktioniert, Leitfäden und öffentliche Abstracts sind erreichbar
Passwort-Login	Anmeldung mit einem Testkonto gelingt; Sitzung bleibt erhalten
2FA	TOTP funktioniert mit bestehendem oder neu eingerichtetem Testkonto
Rollenrechte	Studierende, Erstprüfung, Zweitprüfung, Verwaltung und Superadmin sehen nur ihre freigegebenen Bereiche
E-Mail	Passwort-Reset oder Testmail erreicht ein kontrolliertes Postfach
Upload und Download	Datei wird gespeichert, befugte Rolle kann sie laden, unbefugte Rolle nicht
Kolloquium und Erinnerungen	Testfall kann eine Abstimmung anzeigen; Schedulerstatus ist sichtbar
Export	Prüfungsakte und Verwaltungs-CSV funktionieren
Backup	backup.sh und verify-backup.sh laufen erfolgreich; Restore-Test auf Testserver dokumentiert

Das Skript `scripts/selfhosted/verify-deployment.sh` prüft Compose, Container, lokale HTTP- und öffentliche HTTPS-Antworten. Es ersetzt nicht die Fachtests aus der Tabelle.

1.11 11. DNS- und Domainumstellung

Die Domain `thesis.htw-berlin.com` wird erst umgestellt, wenn die Testliste vollständig bestanden ist. Verringern Sie die DNS-TTL mindestens 24 Stunden vorher auf beispielsweise 300 Sekunden. Halten Sie die bisherige Seite bereit, bis die neue Installation bestätigt ist.

Zeitpunkt	Maßnahme
T-48 Stunden	TTL reduzieren, End-to-End-Test auf Testadresse durchführen
T-24 Stunden	finalen Daten- und Datelexport erstellen, Prüfsummen prüfen
T-2 Stunden	Schreibpausen kommunizieren oder Änderungen eng protokollieren

Zeitpunkt	Maßnahme
T0	A- und gegebenenfalls AAAA-Record auf neue Serveradresse setzen
T+30 Minuten	HTTPS, Login, E-Mail, Upload und Rollenrechte prüfen
T+24 Stunden	alte Umgebung erst nach Freigabe und vollständigem Backup stilllegen

Für Caddy müssen die Ports 80 und 443 vom Internet erreichbar sein, damit Let's Encrypt ein Zertifikat ausstellen kann. Ändern Sie keine Domaininhaberschaft nur für den technischen Umzug.

1.12 12. Regelbetrieb und Wartung

Der Server ist nach der Umstellung ein eigener Betrieb. Ein überschaubarer, fester Wartungsrhythmus ist wirksamer als unregelmäßige Ad-hoc-Eingriffe.

Rhythmus	Aufgabe
täglich	automatisches Backup prüfen, Fehlerlogs und Speicherplatz kontrollieren
wöchentlich	Betriebssystem-Sicherheitsupdates und Docker-Image-Updates bewerten
monatlich	vollständigen Restore-Test oder mindestens einen kontrollierten Teilrestore durchführen
quartalsweise	Berechtigungen, SMTP-Zugang, S3-Zugriff und 2FA-Notfallzugänge überprüfen
jährlich	Datenschutz-, Lösch- und Aufbewahrungskonzept sowie Leitfäden prüfen

Die Mindestregel für Sicherungen ist **3-2-1**: drei Kopien, auf mindestens zwei unterschiedlichen Speichermedien, davon eine Kopie außerhalb des Servers. Für Backups im Object Storage sollten Versionierung und – wenn organisatorisch zulässig – Object Lock verwendet werden. IONOS und Hetzner dokumentieren Object Lock als Schutz gegen Löschung oder Überschreiben. [3] [4]

1.13 13. Notfallplan

Bei einem Ausfall ist zuerst zu klären, ob die Ursache im DNS, im Reverse Proxy, in der Anwendung, in MySQL, im Speicher oder beim SMTP liegt. Nutzen Sie die folgenden Befehle, ohne Geheimnisse in Tickets oder Chat-Protokolle zu kopieren.

```
cd /srv/thesis-match-maker
docker compose --env-file deploy/.env -f deploy/docker-compose.yml ps
docker compose --env-file deploy/.env -f deploy/docker-compose.yml logs --tail=200
app
docker compose --env-file deploy/.env -f deploy/docker-compose.yml logs --tail=200
```

```
db
docker compose --env-file deploy/.env -f deploy/docker-compose.yml logs --tail=200
caddy
```

Wenn Daten inkonsistent wirken oder ein Sicherheitsvorfall vermutet wird, stoppen Sie riskante Schreibvorgänge, sichern Sie Logs und aktuelle Volumes, informieren Sie die verantwortliche Stelle und stellen Sie ausschließlich ein geprüftes Backup wieder her. Ein Restore darf nicht unter Zeitdruck auf dem einzigen Produktionssystem geprobt werden.

1.14 14. Abnahme vor Produktivschaltung

Die Projektleitung gibt die Produktivschaltung erst frei, wenn alle folgenden Aussagen zutreffen:

- Ein konsistenter Datenbankdump und alle Dateixporte liegen verschlüsselt vor.
- Die Prüfsummen des Backups sind geprüft.
- Ein Testrestore wurde dokumentiert.
- Die Anwendung funktioniert auf der Zielumgebung ohne BUILT_IN_FORGE_API_*, OAUTH_SERVER_URL oder VITE_APP_ID.
- SMTP, Dateispeicher, Hintergrundjobs und HTTPS wurden getestet.
- Domain-, Datenschutz- und Notfallverantwortung sind benannt.
- Die DNS-Umstellung ist geplant und kommuniziert.

1.15 Referenzen

- [1]: [IONOS VPS: Tarife, Ressourcen, Root-Zugriff und Sicherheitsfunktionen](#)
- [2]: [Hetzner Cloud: Serveroptionen, Firewall, Standorte und Dokumentation](#)
- [3]: [IONOS Cloud Object Storage: S3-Kompatibilität, Object Lock und Preismodell](#)
- [4]: [Hetzner Object Storage: S3-Kompatibilität, Object Lock und Standorte](#)
- [5]: [Manus: Website-Backups, Inhalt eines Task Data Backups und Schnappschussrisiko](#)

2 Begriffsverzeichnis

2FA – Zwei-Faktor-Authentifizierung: Zusätzliche Anmeldung mit zeitbasiertem Einmalcode.

Cron – Geplante Hintergrundaufgabe: Zeitgesteuerter Prozess für Erinnerungen und regelmäßige Systemaufgaben.

DNS – Domain Name System: Dienst zur Zuordnung einer Domain wie `thesis.htw-berlin.com` zu einer Serveradresse.

S3 – S3-kompatibler Object Storage: Privater Dateispeicher für Uploads und Sicherungen mit standardisierter Programmierschnittstelle.

SMTP – Simple Mail Transfer Protocol: Standardprotokoll für den Versand der System-E-Mails.

TLS – Transport Layer Security: Verschlüsselung für HTTPS-Verbindungen zwischen Browser und Server.